

MEU REAL

MANUAL PROFISSIONAL

Uso, administração, operação, segurança e governança

VISÃO FINANCEIRA

Dashboard e relatórios

AUTOMAÇÃO SEGURA

Money e Telegram

PRIVACIDADE

Exportação e exclusão

OPERAÇÃO

CI, alertas e backup

GOVERNANÇA

Administração e auditoria

Versão 1.0 | 27 de julho de 2026

Responsável pelo produto: Fábio Henrique



Controle do documento

Campo	Informação
Documento	Manual Profissional do Sistema Meu Real
Versão	1.0
Data de emissão	27/07/2026
Responsável pelo produto	Fábio Henrique
Base técnica	Branch main do repositório cfp-money, após a Fase 18
Classificação	Documento controlado - uso operacional, institucional e comercial
Revisão recomendada	Trimestralmente ou após mudança relevante de arquitetura, segurança, privacidade ou modelo comercial
Aprovação jurídica	Pendente - os textos de privacidade e contratação exigem revisão profissional antes do lançamento comercial

Histórico de revisões

Versão	Data	Descrição	Responsável
1.0	27/07/2026	Primeira versão consolidada: usuário, administração, operação, segurança, privacidade, Telegram, continuidade e transferência.	Fábio Henrique

FINALIDADE Este manual consolida o modo de uso e o modelo operacional do Meu Real. Ele não substitui contrato, parecer jurídico, política corporativa de segurança ou procedimento de um provedor de nuvem.

Resumo executivo e situação atual

O Meu Real já dispõe de uma base técnica madura para demonstração, pilotos controlados e evolução comercial: **frontend responsivo, autenticação, dados segregados por usuário, funções privilegiadas, Money, Telegram, privacidade, exclusão de conta, métricas administrativas, CI e índices versionados.**

ESTADO CONFIRMADO A versão atual valida frontend, backend e índices pelo comando `npm run validate:all`. O frontend em GitHub Pages continua classificado como provisório para produção.

O que ainda falta antes de um lançamento público profissional

Prioridade	Frente	Ação necessária
P0 - crítico	Ambientes separados	Criar projetos Firebase independentes para desenvolvimento, homologação e produção.
P0 - crítico	Domínio e hospedagem	Definir domínio próprio, TLS, política de cache e hospedagem de produção; GitHub Pages permanece provisório.

Prioridade	Frente	Ação necessária
P0 - crítico	Segredos e Telegram	Configurar Secret Manager, bot, webhook e rotação inicial de segredos no projeto de produção.
P0 - crítico	App Check	Validar tokens no domínio definitivo e habilitar enforcement gradualmente.
P0 - crítico	Backup e restauração	Criar backup programado, definir retenção e executar teste documentado de restauração.
P0 - crítico	Monitoramento	Criar alertas de erro, disponibilidade, latência, falha de agendamento, orçamento e backup.
P0 - crítico	Jurídico e LGPD	Revisar Termos, Política, controlador, operadores, retenção, canal do titular e resposta a incidentes.
P1 - alta	Segurança do pipeline	Fixar GitHub Actions por SHA, ativar Dependabot/CodeQL e revisar permissões mínimas.
P1 - alta	Cobrança e suporte	Definir pagamento, cancelamento, recibos, canal oficial e SLA. O fluxo Pix manual não escala.
P1 - alta	Qualidade não funcional	Executar testes de acessibilidade, desempenho, carga, segurança e recuperação.
P2 - evolução	B2B e setor público	Preparar multiambiente por organização, relatórios institucionais, contratos, DPA e evidências de segurança.
P2 - evolução	Propriedade intelectual	Definir licença, marca, cessões, repositório privado comercial e documentação de transferência.

Sumário

1. Objetivo, escopo e princípios
 2. Visão do produto e arquitetura
 3. Papéis e responsabilidades
 4. Manual do usuário
 5. Manual do administrador
 6. Operação técnica e implantação
 7. Segurança e desenvolvimento seguro
 8. Privacidade e LGPD
 9. Monitoramento, backup e continuidade
 10. Suporte, manutenção e incidentes
 11. Comercialização e transferência do ativo
 12. Plano de entrada em produção
 13. Checklists operacionais
- Apêndices

1. Objetivo, escopo e princípios

Este manual estabelece uma referência única para uso, administração e operação do Meu Real. O conteúdo foi organizado para servir a cinco públicos: usuário final, administrador funcional, operador técnico, responsável por segurança e privacidade e responsável comercial.

1.1 Escopo

- Uso das funções disponíveis no aplicativo web.
- Administração de usuários, planos, bloqueios e métricas agregadas.
- Configuração e operação do backend Firebase e da integração com Telegram.
- Validação, release, implantação, monitoramento, backup e resposta a incidentes.
- Governança de dados, direitos do titular, transferência e preparação comercial.

1.2 Princípios operacionais

Princípio	Aplicação prática
Privacidade por padrão	Nenhuma função deve expor dados financeiros individuais fora do usuário autorizado.
Confirmação antes de gravar	Money e Telegram devem apresentar rascunho e exigir confirmação em operações sensíveis.
Menor privilégio	A administração depende de custom claim confiável; e-mail ou campo editável no cliente não concede privilégio.
Segredos fora do frontend	Tokens, chaves privadas e segredos permanecem no Secret Manager ou em ambiente seguro.
Mudança verificável	Toda release deve gerar evidências de lint, testes, build e validação dos índices.
Reversibilidade	Alterações críticas precisam de plano de rollback, backup e responsáveis definidos.
Transparência	O usuário deve conhecer finalidade, tratamento, exportação e exclusão de seus dados.

BOA PRÁTICA O OWASP ASVS 5.0.0 pode ser adotado como referência de verificação técnica e também como critério em contratação e aquisição de software [R7].

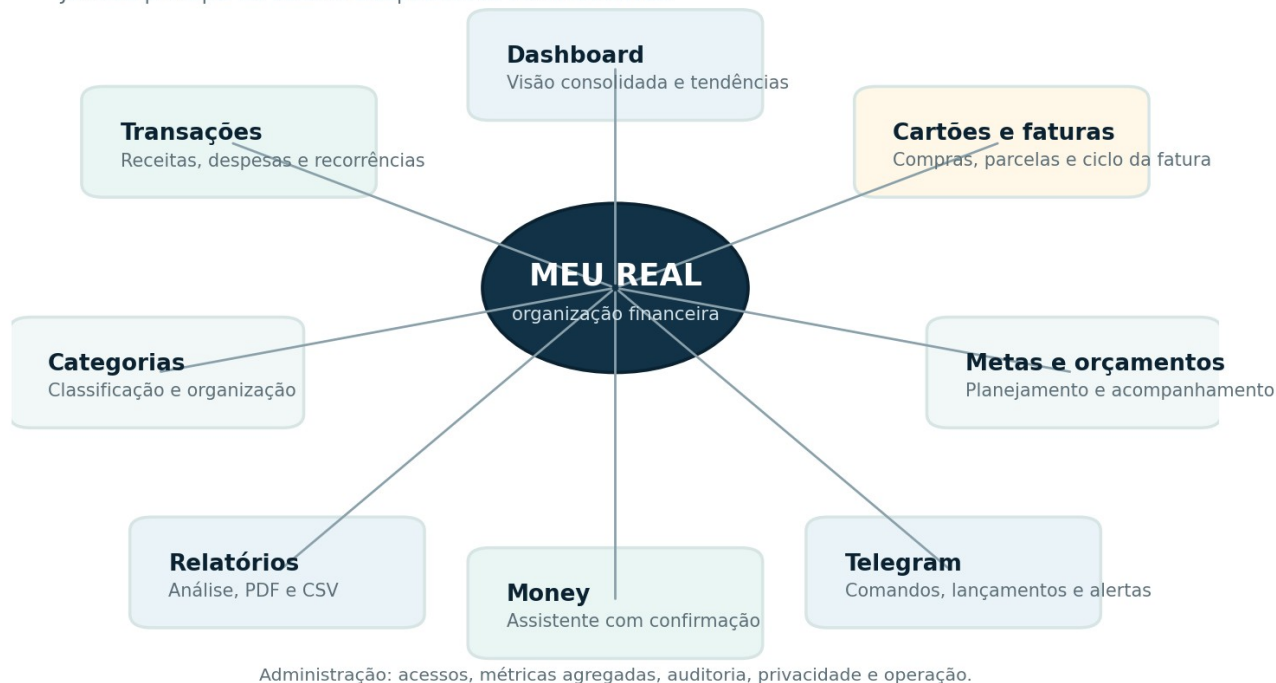
[Voltar ao sumário](#)

2. Visão do produto e arquitetura

O Meu Real é uma aplicação web de organização financeira pessoal. A solução reúne controle de receitas e despesas, cartões, faturas, metas, orçamentos, relatórios, assistente Money, integração opcional com Telegram, administração Premium e mecanismos de privacidade.

Mapa funcional do produto

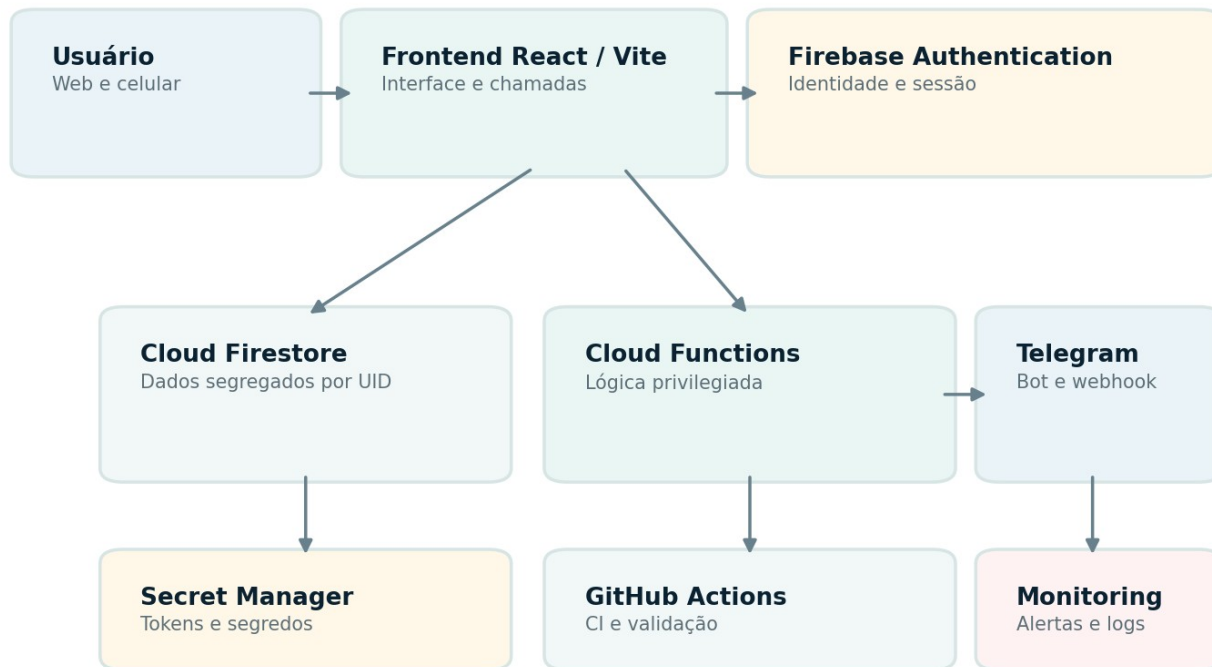
Jornada principal do usuário e capacidades administrativas.



2.1 Arquitetura lógica

Arquitetura lógica e fronteiras de confiança

Segredos e operações privilegiadas permanecem no backend.



2.2 Fronteiras de confiança

- O navegador executa apresentação e chamadas autenticadas, mas não recebe segredos do backend.
- Firebase Authentication controla identidade, sessão e custom claims.
- Cloud Firestore armazena dados financeiros em `users/{uid}/...` e aplica regras por proprietário.
- Cloud Functions executam ações privilegiadas, integração, automações, privacidade e métricas.
- Coleções de auditoria, códigos temporários, vínculos e filas de exclusão não são graváveis pelo cliente.

- A integração Telegram é opcional e usa código temporário, HMAC, webhook secreto e conversas privadas.

2.3 Estado de hospedagem

ESTADO ATUAL O frontend utiliza GitHub Pages de forma temporária. Para produção, recomenda-se domínio próprio, ambiente separado e hospedagem com TLS, controle de cache, cabeçalhos de segurança e procedimento de reversão.

[Voltar ao sumário](#)

3. Papéis e responsabilidades

Papel	Responsabilidade
Usuário final	Registra e revisa dados, protege credenciais, confirma rascunhos e reporta acessos não reconhecidos.
Administrador funcional	Gerencia acesso Premium, bloqueios, métricas e atendimento de primeiro nível.
Operador técnico	Mantém ambientes, segredos, deploys, alertas, backups, logs e restauração.
Product Owner	Prioriza roadmap, aprova escopo, aceita releases e coordena requisitos comerciais.
Segurança e privacidade	Revisa controles, incidentes, riscos, operadores, direitos dos titulares e evidências.
Jurídico/comercial	Valida Termos, Política, preço, contratos, SLA, licenças, marca e transferência.

3.1 Matriz RACI simplificada

Processo	Aprova	Executa	Consulta	Informa
Nova release	PO	Operador	Segurança/Admin	Usuários afetados
Alteração de regras	Segurança	Operador	PO	Admin
Incidente de dados	Controlador/Privacidade	Operador	Jurídico/PO	Titulares e ANPD, quando aplicável
Backup e restauração	Operador	Operador	PO/Segurança	Admin
Mudança de preço	Comercial/PO	Admin	Jurídico	Usuários
Transferência do ativo	Titular do ativo	Operador/Jurídico	Segurança/Comprador	Partes interessadas

CONTROLE DE ACESSO A custom claim admin deve ser emitida somente em ambiente confiável. A remoção de privilégio deve ser acompanhada de revogação de tokens e validação da sessão.

[Voltar ao sumário](#)

4. Manual do usuário

4.1 Acesso e primeiro uso

1. Acesse o endereço oficial informado pelo operador.
2. Entre com e-mail e senha ou com o provedor Google, quando habilitado.

3. Revise os Termos de Uso e a Política de Privacidade apresentados.
4. Conclua o onboarding e confira o plano disponível.
5. Ajuste nome, foto e preferências no Perfil.

SEGURANÇA DO USUÁRIO Não compartilhe senha, código de vinculação do Telegram ou sessão ativa. Em caso de suspeita, altere a senha e solicite revisão do acesso.

4.2 Navegação principal

Área	Finalidade
Dashboard	Visão consolidada, saldos, tendências e atalhos.
Money	Assistente financeiro conversacional com confirmação antes de salvar; recurso Premium.
Cartões	Cartões, compras, parcelas, ciclos e faturas; recurso Premium.
Transações	Cadastro e consulta de receitas e despesas.
Categorias	Organização e classificação dos lançamentos.
Metas	Objetivos financeiros e progresso.
Orçamentos	Limites por categoria ou período.
Relatórios	Análises e exportações.
Perfil	Conta, plano, senha, privacidade e integrações.
Admin	Área restrita a administradores.

4.3 Dashboard

- Use o Dashboard para conferir visão geral do período, entradas, saídas e comportamento das despesas.
- Antes de tomar decisão, confira se o período e os filtros representam o intervalo desejado.
- Diferenças inesperadas normalmente decorrem de lançamento duplicado, data incorreta, categoria inadequada ou compra parcelada em outra fatura.

4.4 Transações e categorias

1. Selecione Transações e escolha o tipo: receita ou despesa.
2. Informe descrição, valor, data, categoria e forma de pagamento.
3. Revise recorrência, parcelamento e observações antes de salvar.
4. Edite ou exclua somente após confirmar o impacto em relatórios, faturas e orçamentos.

QUALIDADE DOS DADOS Padronize descrições curtas e categorias estáveis. Evite criar categorias semelhantes com grafias diferentes.

4.5 Cartões, compras e faturas

- Cadastre cada cartão com nome identificável, fechamento e vencimento corretos.
- Em compras parceladas, confirme valor total, número de parcelas e data da compra.
- O sistema distribui as parcelas de acordo com o ciclo do cartão; confira a primeira fatura antes de confirmar.
- Registre o pagamento da fatura conforme o fluxo disponível e evite lançar a mesma despesa novamente como pagamento comum.
- Mudanças em fechamento ou vencimento devem ser avaliadas antes de alterar cartões já utilizados.

4.6 Metas e orçamentos

Recurso	Uso recomendado	Cuidados
Metas	Objetivos com valor-alvo e prazo.	Atualize contribuições e não confunda saldo disponível com progresso da meta.
Orçamentos	Limite de gasto por categoria e período.	Revise categorias associadas e acompanhe alertas antes do encerramento do período.

4.7 Relatórios

- Selecione o período correto antes de exportar.
- Use PDF para apresentação e CSV para análise ou conferência externa.
- Revise totais e categorias antes de compartilhar o arquivo.
- Relatórios contêm informações financeiras: compartilhe somente com destinatários autorizados.

4.8 Assistente Money

Tipo	Exemplo de mensagem
Consulta	Como estão minhas finanças neste mês?
Despesa	Paguei R\$ 180 no dentista por Pix ontem.
Receita	Recebi R\$ 1.500 de renda extra.
Cartão	Comprei R\$ 600 no Nubank em 3 vezes no mercado.

CONFIRMAÇÃO OBRIGATÓRIA O Money prepara rascunhos. O usuário deve revisar valor, categoria, data, cartão e parcelas antes de confirmar. O assistente não substitui aconselhamento financeiro profissional.

4.9 Integração com Telegram

1. No Meu Real, gere o código temporário de vinculação.
2. Abra o bot oficial no Telegram e envie /vincular CODIGO.
3. Confirme o vínculo e ajuste preferências de resumo e alertas.
4. Use /saldo, /resumo, /ultimos e mensagens em linguagem natural.
5. Confirme ou cancele cada rascunho apresentado pelo bot.
6. Use /desvincular ou o Perfil para encerrar a integração.

PRIVACIDADE NO TELEGRAM Use apenas conversa privada com o bot oficial. Não encaminhe códigos ou dados financeiros para grupos e não confunda bots com nomes semelhantes.

4.10 Perfil, exportação e exclusão

- O Perfil permite atualizar nome, foto e senha.
- A área Privacidade e dados apresenta documentos jurídicos, exportação e encerramento da conta.

- A exportação gera arquivo JSON com dados vinculados à conta, sem incluir segredos do backend.
- A exclusão exige frase de confirmação e possui prazo de segurança de sete dias para cancelamento.
- Antes de excluir, gere e guarde a exportação desejada.

[Voltar ao sumário](#)

5. Manual do administrador

A área Admin é restrita a usuários cuja sessão contém a custom claim admin=true. O administrador não deve receber acesso somente por e-mail, cadastro no Firestore ou alteração feita pelo navegador.

5.1 Gestão de usuários e planos

- Localize o usuário por nome ou e-mail.
- Ative Premium pelo período aprovado e registre a evidência comercial correspondente.
- Remova Premium somente após validar motivo, comunicação e impacto.
- Use bloqueio para fraude, risco de segurança, solicitação jurídica ou descumprimento contratual.
- Toda alteração administrativa deve ser executada pelo backend e gerar auditoria.

5.2 Métricas operacionais

Indicador	Interpretação
Usuários	Quantidade de contas registradas.
Adoção do Telegram	Percentual e quantidade de vínculos ativos.
Aceite jurídico	Usuários na versão atual de Termos e Política.
Fila de exclusão	Solicitações pendentes, em processamento ou com falha.
Prontidão técnica	Controles implementados e pendência de App Check.

LIMITE Métricas administrativas são agregadas. O administrador não deve usar o painel para acessar ou interpretar a vida financeira individual de usuários.

5.3 Rotina recomendada do administrador

Frequência	Atividades
Diária	Verificar falhas de função, fila de exclusão, alertas críticos e solicitações de acesso.
Semanal	Revisar bloqueios, pagamentos pendentes, vínculos de Telegram e tickets recorrentes.
Mensal	Revisar permissões, custos, métricas, vulnerabilidades, backup e relatórios operacionais.
Trimestral	Revisar Termos, Política, SLA, responsáveis, roadmap e continuidade.

[Voltar ao sumário](#)

6. Operação técnica e implantação

6.1 Ambientes

RECOMENDAÇÃO OFICIAL Use um projeto Firebase separado para cada ambiente. Builds de desenvolvimento e produção não devem compartilhar os mesmos dados e recursos [R1].

Ambiente	Finalidade	Dados	Acesso
Desenvolvimento	Construção e testes locais.	Fictícios ou anonimizados.	Equipe técnica.
Homologação	Aceite funcional, integração e release candidate.	Fictícios e representativos.	Equipe, PO e homologadores.
Produção	Uso real.	Dados reais sujeitos à LGPD.	Usuários e operadores autorizados.

6.2 Preparação do ambiente local

```
nvm use 20
npm ci
npm install --prefix functions
cp .env.example .env
npm run dev
```

SEGREDO O arquivo .env local não deve ser enviado ao Git. Chaves privadas, tokens do bot e credenciais de service account nunca usam prefixo VITE_.

6.3 Inventário mínimo de variáveis e segredos

Nome	Tipo	Finalidade
VITE_FIREBASE_*	Pública	Configuração do app web e identificação do projeto.
VITE_RECAPTCHA_ENTERPRISE_SITE_KEY	Pública	Atestação do App Check no frontend.
VITE_TELEGRAM_BOT_USERNAME	Pública	Nome público do bot.
VITE_LEGAL_CONTROLLER_NAME	Pública	Identidade do controlador apresentada ao usuário.
VITE_LEGAL_CONTACT_EMAIL	Pública	Canal de privacidade e suporte jurídico.
VITE_ENFORCE_LEGAL_GATE	Pública	Bloqueio estrito quando a validação jurídica está indisponível.
ENFORCE_APP_CHECK	Parâmetro backend	Exige token válido nas funções chamáveis.
INTEGRATION_LINK_SECRET	Secret Manager	HMAC dos códigos de integração.
TELEGRAM_BOT_TOKEN	Secret Manager	Credencial do bot.
TELEGRAM_WEBHOOK_SECRET	Secret Manager	Validação do webhook.

6.4 Validação completa

```
npm run validate:all  
npm run format:check
```

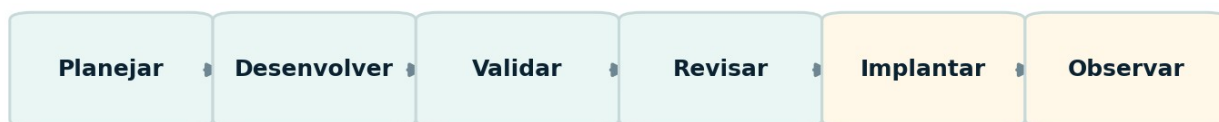
- validate:all executa lint, testes, build, validação do backend e validação dos índices.
- A release deve ser bloqueada em caso de erro; avisos precisam ser registrados e avaliados.
- O GitHub Actions deve produzir evidência reprodutível da validação em push e pull request.

6.5 Implantação

```
npx firebase-tools@latest deploy --only firestore,functions  
npm run deploy
```

ANTES DE IMPLANTAR Confirme o projeto ativo, branch, commit, ambiente, segredos, índices, plano de reversão, janela de mudança e responsável por observar a release.

Fluxo de mudança e release



Nenhuma implantação sem validação completa, evidência de CI e plano de reversão.

[Voltar ao sumário](#)

7. Segurança e desenvolvimento seguro

7.1 Controles já presentes

- Dados financeiros segregados por UID e regras de acesso por proprietário.
- Operações administrativas no backend com autenticação e custom claim.
- Segredos definidos no Secret Manager.
- Códigos de vinculação temporários protegidos por HMAC.
- Telegram limitado a conversas privadas e webhook com segredo.
- Auditoria administrativa, consentimento jurídico e registro pseudonimizado de exclusão.
- CI com lint, testes, build e índices versionados.

7.2 App Check

O App Check adiciona atestação às requisições e permite rejeitar clientes não autorizados. Ele reduz abuso, mas não substitui Authentication, regras do Firestore, autorização do backend ou gestão de segredos [R2].

1. Registrar o domínio definitivo no provedor de atestação.
2. Observar métricas sem enforcement para identificar clientes legítimos.
3. Corrigir origens sem token válido.
4. Ativar ENFORCE_APP_CHECK gradualmente.
5. Manter procedimento de rollback caso usuários legítimos sejam bloqueados.

7.3 Pipeline e repositório

- Use proteção da branch main, pull request e revisão obrigatória para mudanças críticas.
- Restrinja permissions do GitHub Actions ao mínimo necessário.
- Fixe actions de terceiros por SHA completo para imutabilidade do código executado [R6].
- Ative Dependabot, revisão de dependências e CodeQL ou ferramenta equivalente.
- Use Security Advisories para vulnerabilidades; não publique detalhes exploráveis em issues.
- Mantenha o repositório comercial privado quando houver ativos, clientes ou configurações sensíveis.

7.4 Verificação de segurança

Domínio	Evidência esperada
Autenticação	Sessão, revogação, reset, provedores e MFA para operadores.
Autorização	Regras por UID, claims e funções administrativas.
Validação de entrada	Valores, datas, mensagens, IDs e limites.
Segredos	Armazenamento, rotação, acesso e auditoria.
Logs	Ausência de tokens e dados financeiros desnecessários.
Dependências	Vulnerabilidades, atualizações e licenças.
Resiliência	Rate limits, quotas, maxInstances, timeouts e filas.
Privacidade	Minimização, portabilidade, exclusão e incidentes.

REFERÊNCIA Adote um checklist de verificação baseado no OWASP ASVS 5.0.0 e registre exceções, riscos aceitos e evidências [R7].

[Voltar ao sumário](#)

8. Privacidade e LGPD

8.1 Dados tratados

Categoria	Exemplos
Cadastro e autenticação	Nome, e-mail, identificadores, provedores e metadados de sessão.
Dados financeiros	Receitas, despesas, cartões, faturas, metas, orçamentos, categorias e observações.
Integração	Identificador do Telegram, preferências, mensagens e rascunhos necessários à execução.
Operação e segurança	Logs, auditoria, consentimentos, solicitações de exclusão e indicadores agregados.

8.2 Direitos e fluxos implementados

- Consulta dos Termos de Uso e da Política de Privacidade.
- Aceite versionado com data e histórico.
- Exportação dos dados em JSON.
- Solicitação de exclusão com prazo de segurança de sete dias.
- Cancelamento da exclusão durante o prazo.
- Exclusão recursiva, limpeza de integrações e remoção da identidade no Authentication.

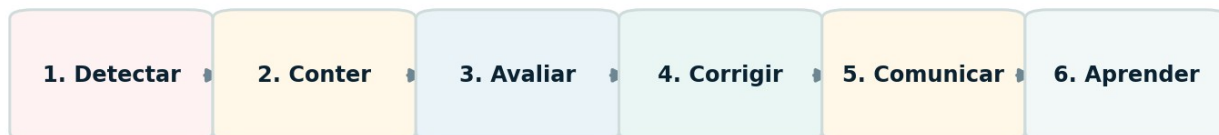
8.3 Governança necessária antes de produção

- Identificar controlador, contato de privacidade e, quando aplicável, encarregado.
- Registrar finalidades, bases legais, operadores, transferências e prazos de retenção.
- Firmar contratos ou termos com fornecedores que tratem dados em nome do controlador.
- Definir processo para solicitações de acesso, correção, informação, oposição e revisão.
- Manter inventário de tratamento e registro de incidentes.
- Revisar os textos jurídicos com profissional habilitado.

8.4 Incidentes com dados pessoais

Dados financeiros e de autenticação recebem atenção reforçada na avaliação de risco. Quando um incidente confirmado puder causar risco ou dano relevante, o controlador deve avaliar comunicação à ANPD e aos titulares. A ANPD exige registro dos incidentes por pelo menos cinco anos [R8].

Resposta a incidentes de segurança e privacidade



Registrar decisões, dados afetados, medidas, comunicações e ações preventivas.

PRAZO E DECISÃO A comunicação regulatória depende da avaliação do controlador e das circunstâncias concretas. O manual operacional deve registrar data de ciência, dados afetados, titulares, riscos, medidas e comunicações.

[Voltar ao sumário](#)

9. Monitoramento, backup e continuidade

9.1 Observabilidade mínima

Alerta	Condição a observar
Erro de Cloud Functions	Aumento de exceções ou função específica falhando.
Disponibilidade e latência	Falha de endpoint, 5xx ou tempo de resposta elevado.
Scheduler	Ausência de execução do digest, alertas ou exclusão de contas.
Firestore	Uso, quota, erros de permissão, índices e falha de consulta.
Custos	Orçamento, anomalia de gasto e crescimento inesperado.
Backup	Programação ausente, backup atrasado ou restauração não testada.
Telegram	Webhook inválido, falhas de API e mensagens não processadas.

BOA PRÁTICA Políticas do Cloud Monitoring devem combinar condição, canal de notificação e documentação com link para o runbook. Alertas podem monitorar métricas, ausência de dados e logs [R5].

9.2 Backup do Firestore

Backups programados protegem contra corrupção no nível da aplicação e exclusão acidental. O recurso permite programação diária ou semanal, retenção configurável e restauração em um novo banco de dados; requer faturamento ativo [R3].

```
firebase firestore:backups:schedules:create --database '(default)' --recurrence DAILY
--retention 14w

firebase firestore:backups:schedules:list --database '(default)'
```

TESTE OBRIGATÓRIO Backup sem teste de restauração não é evidência de continuidade. Execute restauração em banco separado, valide dados e documente data, responsável e resultado.

9.3 Exportações gerenciadas

Exportações para Cloud Storage podem apoiar recuperação, processamento offline e arquivamento. Elas geram leituras cobradas e não substituem integralmente o backup consistente [R4].

9.4 RTO e RPO

Indicador	Meta interna inicial sugerida	Observação
RTO	Até 8 horas	Tempo para restabelecer serviço mínimo; revisar em contratos B2B.
RPO	Até 24 horas	Perda máxima de dados com backup diário; reduzir conforme criticidade.
Retenção de backup	14 semanas	Limite máximo informado para programação; validar custo e política.
Teste de restauração	Trimestral	Executar também após mudança relevante de arquitetura.

NÃO CONTRATUAL As metas acima são referências internas iniciais. SLA, RTO e RPO oficiais precisam de aprovação técnica, financeira e contratual.

[Voltar ao sumário](#)

10. Suporte, manutenção e incidentes

10.1 Classificação de atendimento

Severidade	Exemplo	Resposta sugerida	Contorno sugerido
Crítica	Indisponibilidade geral, risco de dados ou acesso indevido.	1 hora	4 horas
Alta	Função principal indisponível para grupo de usuários.	4 horas	1 dia útil
Média	Erro com alternativa ou impacto limitado.	1 dia útil	3 dias úteis

Severidade	Exemplo	Resposta sugerida	Contorno sugerido
Baixa	Dúvida, solicitação ou melhoria.	2 dias úteis	Planejamento

10.2 Informações mínimas do chamado

- Data, horário e fuso.
- Usuário ou organização afetada, sem expor dados desnecessários.
- Tela, ação e resultado esperado.
- Mensagem de erro e evidência visual quando seguro.
- Navegador, dispositivo e versão.
- Impacto, urgência e existência de contorno.

10.3 Manutenção preventiva

Frequência	Revisão
Semanal	Falhas, alertas, filas e disponibilidade.
Mensal	Custos, permissões, dependências, backup, restauração e métricas.
Trimestral	Segredos, acesso administrativo, documentos jurídicos, riscos e continuidade.
Semestral	Teste de segurança, acessibilidade, desempenho e revisão de arquitetura.
Anual	Plano de negócio, contratos, marca, operadores, política de retenção e transferência.

10.4 Pós-incidente

1. Registrar linha do tempo e evidências.
2. Determinar causa raiz técnica e organizacional.
3. Documentar impacto real e potencial.
4. Definir ações corretivas, preventivas, responsáveis e prazo.
5. Atualizar testes, alertas, runbooks e treinamento.
6. Realizar revisão sem culpabilização e acompanhar reincidência.

[Voltar ao sumário](#)

11. Comercialização e transferência do ativo

11.1 Componentes do ativo

- Código-fonte, histórico Git e documentação.
- Marca, domínio, identidade visual e materiais comerciais.
- Projetos Firebase/Google Cloud e faturamento.
- Bot e conta Telegram.
- Segredos, parâmetros, alertas e backups.
- Contratos, políticas, métricas e base de clientes, quando existentes.

11.2 Data room mínima

Bloco	Evidências
Produto	Funcionalidades, roadmap, demonstração, versões e limitações.

Bloco	Evidências
Tecnologia	Arquitetura, testes, CI, custos, incidentes e dependências.
Segurança e privacidade	Regras, controles, operadores, termos, incidentes e direitos do titular.
Negócio	Usuários, clientes, receita, cancelamento, custos e suporte.
Propriedade intelectual	Autoria, cessões, licenças, marca e domínio.
Transferência	Checklist de acessos, rotação de segredos, implantação e encerramento do suporte.

11.3 Venda integral sem suporte permanente

- Definir claramente cessão integral, ativos incluídos e componentes de terceiros.
- Limitar a transição por prazo e quantidade de horas.
- Excluir manutenção, SLA e evolução futura, salvo contratação separada.
- Separar transferência do software da transferência de dados pessoais.
- Rotacionar segredos, remover acessos do vendedor e alterar faturamento e contatos.
- Registrar aceite técnico da implantação reproduzida pelo comprador.

11.4 Contratação pública

- Adaptar o objeto ao termo de referência, sem prometer funções não implementadas.
- Apresentar implantação, licenciamento, hospedagem, suporte, capacitação, segurança e relatórios.
- Definir critérios de aceite, SLA, privacidade, transferência e continuidade.
- Para educação financeira escolar, acrescentar conteúdo pedagógico, capacitação, indicadores educacionais e proteção de menores.
- Manter comprovação técnica, fiscal, trabalhista e econômico-financeira exigida no edital.

POSICIONAMENTO RECOMENDADO A versão atual se adequa melhor a bem-estar financeiro de servidores e colaboradores do que a um programa educacional escolar completo.

[Voltar ao sumário](#)

12. Plano de entrada em produção

12.1 Etapa 0 - decisão e preparação

- [] Aprovar responsável legal, contato de privacidade, suporte e faturamento.
- [] Definir domínio, hospedagem, ambientes e orçamento mensal.
- [] Aprovar SLA, RTO, RPO, retenção e modelo de cobrança.
- [] Revisar Termos, Política de Privacidade e contratos.

12.2 Etapa 1 - infraestrutura de produção

- [] Criar projeto Firebase de produção e restringir IAM.
- [] Configurar Authentication, Firestore, índices e Functions.
- [] Criar segredos e parâmetros sem reutilizar valores de desenvolvimento.
- [] Configurar domínio, TLS, App Check em observação e webhook do Telegram.
- [] Criar backups, alertas, orçamento e canais de notificação.

12.3 Etapa 2 - homologação final

- [] Executar validate:all e format:check.
- [] Testar login, lançamentos, cartões, faturas, Money, Telegram, exportação e exclusão.
- [] Testar permissões negativas: usuário não acessa Admin ou dados de terceiros.
- [] Testar backup e restauração em banco separado.

- ☐ Testar alerta, incidente simulado e rollback.
- ☐ Validar acessibilidade e desempenho em desktop e celular.

12.4 Etapa 3 - lançamento controlado

- ☐ Iniciar com grupo piloto e dados reais limitados.
- ☐ Observar erros, latência, custos e tickets por pelo menos sete dias.
- ☐ Ativar VITE_ENFORCE_LEGAL_GATE após validar o backend jurídico.
- ☐ Habilitar ENFORCE_APP_CHECK gradualmente após confirmar clientes legítimos.
- ☐ Formalizar aceite do piloto antes de ampliar usuários.

12.5 Etapa 4 - estabilização

- ☐ Revisar incidentes e feedback do piloto.
- ☐ Ajustar alertas, limites e documentação.
- ☐ Confirmar suporte, cobrança e política de cancelamento.
- ☐ Publicar versão controlada do manual e registrar treinamento.

[Voltar ao sumário](#)

13. Checklists operacionais

13.1 Checklist de release

Bloco	Evidência mínima
Código	validate:all, format:check, CI, dependências e changelog.
Firebase	Projeto, regras, índices, funções, segredos, App Check e schedulers.
Produto	Login, transações, cartões, Money, Telegram, exportação, exclusão e Admin.
Operação	Alertas, backup, rollback, janela e responsável de observação.
Comercial	Termos, preço, SLA, suporte, contato e comunicação.

13.2 Checklist mensal

- ☐ Revisar erros e latência das Cloud Functions.
- ☐ Verificar custos, quotas e orçamento.
- ☐ Conferir backup e realizar teste conforme calendário.
- ☐ Revisar administradores, claims e acessos ao projeto.
- ☐ Revisar vulnerabilidades e atualizações sem uso automático de force.
- ☐ Testar exportação, exclusão e cancelamento em conta de teste.
- ☐ Conferir webhook e preferências do Telegram.
- ☐ Registrar incidentes e ações pendentes.

13.3 Checklist de transferência

- ☐ Repositório e histórico transferidos.
- ☐ Firebase, Google Cloud, faturamento, domínio e DNS transferidos.
- ☐ Bot e usuário do Telegram transferidos.
- ☐ Segredos rotacionados e acessos antigos removidos.
- ☐ Comprador reproduziu implantação e validação.
- ☐ Dados pessoais tratados conforme base jurídica e contrato.
- ☐ Escopo e prazo de transição encerrados formalmente.

[Voltar ao sumário](#)

Apêndices

Apêndice A - Comandos operacionais essenciais

```
# Desenvolvimento
nvm use 20
npm ci
npm install --prefix functions
npm run dev

# Validação
npm run validate:all
npm run format:check

# Implantação
npm run firebase-tools@latest deploy --only firestore,functions
npm run deploy

# Índices
npm run validate:indexes
npm run deploy:indexes

# Telegram
npm run telegram:webhook --prefix functions
```

Apêndice B - Modelo de registro de incidente

Campo	Conteúdo
Identificador	INC-AAAA-NNN
Data e hora de ciência	A preencher
Responsável	A preencher
Descrição	Circunstâncias e evento confirmado
Dados e titulares	Categorias, volume e grupos afetados
Risco e impacto	Confidencialidade, integridade, disponibilidade e autenticidade
Contenção	Medidas imediatas
Correção	Ações técnicas e organizacionais
Comunicação	ANPD, titulares, fornecedores e partes interessadas
Encerramento	Causa raiz, evidências e prevenção
Retenção	Manter registro pelo período aplicável; referência ANPD: mínimo de cinco anos para incidentes com dados pessoais.

Apêndice C - Glossário

Termo	Definição
App Check	Atestação de que a requisição se origina de cliente autorizado.
CI	Integração contínua com validações automáticas.
Custom claim	Atributo confiável inserido no token do usuário pelo backend.
HMAC	Código de autenticação baseado em hash e segredo.

Termo	Definição
RPO	Quantidade máxima aceitável de dados perdidos em uma recuperação.
RTO	Tempo máximo desejado para restabelecer o serviço.
SLA	Níveis de serviço acordados contratualmente.
Titular	Pessoa natural a quem os dados pessoais se referem.

Apêndice D - Referências

Ref.	Fonte	Endereço
R1	Firebase. Práticas recomendadas gerais para configurar projetos. Recomenda projetos separados por ambiente.	https://firebase.google.com/docs/projects/dev-workflows/general-best-practices?hl=pt-br
R2	Firebase. App Check. Proteção de backends contra clientes não autorizados.	https://firebase.google.com/docs/app-check
R3	Firebase. Fazer backup e restaurar dados do Firestore.	https://firebase.google.com/docs/firestore/backups?hl=pt-BR
R4	Firebase. Exportar/importar e programar exportações do Firestore.	https://firebase.google.com/docs/firestore/manage-data/export-import
R5	Google Cloud. Cloud Monitoring - políticas de alerta, incidentes e canais de notificação.	https://cloud.google.com/monitoring/alerts
R6	GitHub Docs. Uso seguro do GitHub Actions e fixação de actions por SHA completo.	https://docs.github.com/en/actions/reference/security/secure-use
R7	OWASP. Application Security Verification Standard - ASVS 5.0.0.	https://owasp.org/www-project-application-security-verification-standard/
R8	ANPD. Comunicação de Incidente de Segurança e Resolução CD/ANPD nº 15/2024.	https://www.gov.br/anpd/pt-br/canais_atendimento/agente-de-tratamento/comunicado-de-incidente-de-seguranca-cis
R9	Repositório Meu Real - branch main e documentação técnica interna.	https://github.com/fhenriquefcruz/cfp-money

ENCERRAMENTO Este manual deve acompanhar o produto, ser versionado com as releases e receber revisão sempre que houver mudança relevante de arquitetura, fornecedor, dado tratado, contrato ou risco.

[Voltar ao sumário](#)

MEU REAL

Manual Profissional - Versão 1.0

Documento elaborado com base na versão main do projeto em 27/07/2026.